

Malicious PDF Detection with Machine Learning

SLIDE

01

DELIVERY FOCUS

Introduce the project as a practical case study of the course method.

TARGET 90 SECONDS**0:00 - 0:30**

55 WORDS

Good morning. This project applies the methods from Data Science Methods for Cybersecurity to malicious PDF detection. A PDF is a useful business document, but it is also a structured container that may include scripts, actions, embedded files, compressed objects, and malformed references. The security problem is therefore not simply to recognize a suspicious word.

0:30 - 1:00

56 WORDS

It is to combine many weak structural signals into a reliable decision without executing the file. The system performs bounded static analysis, converts document structure into engineered numerical features, and uses supervised machine learning to estimate whether the file should be treated as malicious. The output is connected to a threshold, an uncertainty path, an explanation,

1:00 - 1:30

58 WORDS

and an operational response. This presentation follows the logic emphasized in the course: define the asset and threat model, understand the data, prevent leakage, engineer meaningful features, compare suitable models, interpret precision and recall, explain predictions, consider adversarial behavior, and monitor the system after deployment. The main result is a complete cybersecurity decision pipeline, not only a classifier.

The security objective starts with the threat model

DELIVERY FOCUS

Define the asset, threat, CIA impact, and role of layered controls.

TARGET 90 SECONDS

0:00 - 0:30

56 WORDS

The first course principle is to begin with the security objective, not the algorithm. The protected asset is the trusted document workflow: users, endpoints, and business processes should be able to receive PDFs without allowing hidden behavior to compromise them. The threat is a crafted PDF whose internal structure attempts to trigger code, redirect the reader,

0:30 - 1:00

56 WORDS

hide embedded content, confuse a parser, or evade simple rules. This connects directly to the CIA triad. Confidentiality may be affected when a document exfiltrates information or opens an external channel. Integrity may be affected when actions or embedded content alter the expected workflow. Availability may be affected when malformed or oversized structures exhaust parsing resources.

1:00 - 1:30

65 WORDS

The attacker considered here mainly acts at inference time by changing the PDF while preserving its intended behavior. The project responds with static inspection, strict resource limits, canonicalization, and an abstention option. The detector is a detective control that supports prevention and response; it does not replace patching, sandboxing, endpoint protection, or analyst investigation. A model score is evidence, not automatic proof of an attack.

A PDF becomes a supervised learning observation

DELIVERY FOCUS

Explain the observation unit, positive class, and train-serve contract.

TARGET 90 SECONDS

0:00 - 0:30

60 WORDS

The learning task is binary supervised classification. The observation unit is one PDF, represented by static structural measurements. The positive class is malicious and the negative class is benign. During training, the system receives labeled feature records. During inference, a bounded parser extracts the same feature schema from an uploaded file. Examples include file size, page and object counts, streams,

0:30 - 1:00

61 WORDS

filters, JavaScript markers, actions, embedded files, encryption, object streams, cross-reference structure, and parser-health indicators. The model does not read intent directly. It learns statistical associations between these features and the known labels. That distinction matters because correlation and prediction are not causation. A benign form may contain active elements, while a malicious file may hide them through encoding or structural manipulation.

1:00 - 1:30

58 WORDS

The decision therefore depends on combinations and context rather than one keyword. The project also keeps unavailable values as missing information instead of inventing them or mapping every missing value to zero. The central design contract is train-serve consistency: feature meaning, preprocessing, ordering, and missingness handling must remain identical when the model is used on a new file.

The workflow connects evidence to response

DELIVERY FOCUS

Walk through the complete evidence-to-response workflow in order.

TARGET 90 SECONDS

0:00 - 0:30

57 WORDS

This is the central workflow of the project and it follows the cybersecurity analysis pipeline from the course. First, context and governance define the asset, positive class, threat model, label source, and permitted use. Second, data validation checks provenance, schema, missing codes, duplicates, and label quality. Third, exploratory analysis studies distributions, imbalance, associations, and possible leakage. Fourth,

0:30 - 1:00

58 WORDS

feature engineering converts PDF structure into stable counts, densities, consistency gaps, interactions, complexity measures, and parser-health signals. Fifth, the data is partitioned before any trainable preprocessing is fitted. Sixth, baseline, tree-based, and neural candidates are trained and compared. Seventh, probability calibration and threshold selection translate the model output into an operating policy based on false-positive and false-negative cost.

1:00 - 1:30

57 WORDS

Eighth, inference preserves raw evidence, produces a probability, and can abstain when parsing or confidence is unreliable. Finally, the outcome is connected to analyst review, containment, sandbox escalation, monitoring, and verified feedback. The feedback loop is controlled so alerts confirmed by analysts become future labels. This workflow makes each decision traceable from file structure to security action.

EDA prevents leakage before modeling begins

DELIVERY FOCUS

Show how EDA and split-first preprocessing prevent misleading results.

TARGET 90 SECONDS

0:00 - 0:30

58 WORDS

Exploratory data analysis is a security control for the learning process. Before fitting a model, the project checks feature names and types, invalid and infinite values, missing and sentinel codes, duplicate identifiers, label consistency, unusual ranges, and feature availability. Distribution views reveal skewed counts and heavy tails, while association checks help detect redundant signals and possible label leakage.

0:30 - 1:00

68 WORDS

Missingness is interpreted rather than silently converted into a real measurement. The project also separates identifiers and provenance fields from predictive inputs. Imbalance is evaluated because accuracy alone can hide rare-class failure, especially when malicious prevalence differs from the environment where the model will operate. Preprocessing is never fitted globally. Imputation, transformations, feature selection, calibration, and threshold choice are learned only from their authorized training or validation role.

1:00 - 1:30

58 WORDS

This protects the evaluation from information leaking backward from held-out examples. The same principle applies to related files or campaigns: they should not be allowed to appear on both sides of a split when that would make the test easier than deployment. EDA therefore determines whether the later model result is meaningful before any performance number is trusted.

Feature engineering represents behavior, not keywords

DELIVERY FOCUS

Connect each engineered feature family to structural security meaning.

TARGET 90 SECONDS

0:00 - 0:30

57 WORDS

Raw PDF counts are useful, but cybersecurity meaning often appears in relationships between fields. The project therefore builds several feature families. Scale-stable transformations reduce the influence of extreme counts without removing their ordering. Density features normalize actions, objects, streams, or embedded content by file size, page count, or structural totals. Consistency features compare pairs that should agree,

0:30 - 1:00

56 WORDS

such as object and end-object counts, stream and end-stream counts, or cross-reference and trailer information. Interaction features capture combinations such as an automatic action appearing together with JavaScript or active content appearing inside an encrypted structure. Complexity features summarize concentration and structural diversity. Parser-health features expose invalid headers, truncation, cross-reference problems, and disagreement between extraction views.

1:00 - 1:30

55 WORDS

These engineered variables combine weak indicators instead of treating one token as proof. Every transformation has named lineage back to the original observation, which supports audit and explanation. Missing values are imputed using training statistics while missingness remains visible. The result is a tabular representation designed for tree models, baselines, calibration, and consistent live extraction.

Model selection follows the tabular evidence

DELIVERY FOCUS

Compare baselines, trees, and neural controls without assuming a winner.

TARGET 90 SECONDS

0:00 - 0:30

59 WORDS

The course compares transparent baselines, tree ensembles, boosting, support vector machines, and neural networks, each with different strengths and trade-offs. This project follows that principle instead of assuming that a complex architecture must win. Logistic regression provides a transparent linear baseline. Extra Trees and boosting methods can learn nonlinear thresholds and interactions that are common in structured security data.

0:30 - 1:00

61 WORDS

A fully connected neural network is retained as a control, and a transformer-style tabular model can be evaluated when the available data and compute justify it. Tree-based methods are especially suitable here because the inputs mix counts, binary indicators, missingness patterns, and engineered relationships. After training, raw scores are calibrated so that probability quality can be assessed separately from ranking quality.

1:00 - 1:30

54 WORDS

Threshold selection then uses validation data and an explicit security cost: missing a malicious file is expensive, but too many false alerts can overwhelm analysts. The selected operating point therefore emphasizes recall while preserving usable precision. Model, preprocessing, calibrator, feature schema, and threshold are packaged together so incompatible components cannot be mixed during inference.

Performance is interpreted through operational metrics

DELIVERY FOCUS

Interpret the 90%+ summary through precision, recall, F-scores, and ROC.

TARGET 90 SECONDS

0:00 - 0:30

57 WORDS

The held-out validation results are summarized conservatively as above ninety percent across the core classification metrics. The important course lesson is what each metric means. Precision asks: among the files flagged as malicious, how many are truly malicious? It represents alert quality and directly affects analyst workload. Recall asks: among all malicious files, how many were detected?

0:30 - 1:00

66 WORDS

It represents threat coverage and is critical when missed attacks have high cost. F1 balances precision and recall equally. F2 gives recall more weight, matching the project policy that false negatives are more harmful than a moderate increase in false positives. ROC-AUC measures how well the model ranks malicious above benign examples across possible thresholds, but it does not by itself define the deployed operating point.

1:00 - 1:30

56 WORDS

Accuracy is not used as the main story because it can hide failure under class imbalance. The final threshold is selected using validation evidence, calibration, expected prevalence, response capacity, and the relative cost of false positives and false negatives. Performance must always be reported with its decision policy and operational interpretation, not as one isolated score.

Explainability turns a score into an investigation

DELIVERY FOCUS

Separate observed facts, model attribution, and analyst response.

TARGET 90 SECONDS

0:00 - 0:30

55 WORDS

Explainability is separated into observed evidence and model behavior. The first layer records facts produced by the parser, such as action tokens, JavaScript markers, embedded files, obfuscation, encryption, structural gaps, or parser-health warnings. These observations describe the file, but they do not prove intent. The second layer explains how the model used the feature representation.

0:30 - 1:00

59 WORDS

Local probability changes show which features moved a particular prediction relative to a real training background. Global permutation importance, model importance, feature-family ablation, effect curves, stability analysis, negative controls, and faithfulness checks test whether the explanation is dependable. This goes beyond displaying a SHAP plot without validation. The project also follows the course warning that attribution is not causality,

1:00 - 1:30

59 WORDS

correctness, or guilt. The interface keeps raw facts and model contributions visually separate, then connects them to an action. A confident malicious verdict can trigger sandboxing or containment; parser failure or an out-of-distribution profile can trigger abstention and manual review; a benign verdict can support release. This mirrors the SOC sequence of alert, triage, investigation, response, and verified feedback.

Layered defenses make the classifier operationally useful

DELIVERY FOCUS

Explain evasion defenses and close with the course-wide methodology.

TARGET 90 SECONDS

0:00 - 0:30

59 WORDS

The final course connection is adversarial machine learning. An attacker may change names, whitespace, object numbering, filters, metadata, nesting, cross-reference structure, or parser-visible syntax while preserving malicious behavior. The project tests these ideas with safe, inert mutation families and no live payload execution. The defense is layered because no single preprocessing trick provides robustness. Canonicalization reduces superficial encoding changes.

0:30 - 1:00

57 WORDS

Multiple extraction views reduce dependence on one parser interpretation. Size, time, and nesting limits protect availability. Parser-health and out-of-distribution checks reveal inputs that do not resemble the training conditions. A threshold margin allows the system to abstain rather than force a confident label. Monitoring looks for drift, evasion patterns, unusual queries, and changing false-positive or false-negative cost.

1:00 - 1:30

56 WORDS

Verified difficult cases can later support controlled retraining and rollback. The overall lesson matches the course: define the target and threat model, validate the data, engineer meaningful signals, compare models, interpret operational metrics, explain evidence, plan a response, and monitor the adversary. Machine learning improves triage, but trustworthy cybersecurity still requires layered controls and human judgment.

Feedback became enforceable data and modeling gates

DELIVERY FOCUS

Show how data, prevalence, features, and model selection became enforceable gates

TARGET 90 SECONDS

0:00 - 0:30

60 WORDS

The first group of professor comments became implemented acceptance gates. The project author manually verified a dataset containing more than one million rows, while the streaming pipeline validates source provenance, schema, row quality, and split integrity without loading the full table into memory. The project preserves a realistic prevalence of at least 99.5 percent benign records in training, validation,

0:30 - 1:00

59 WORDS

and test. Duplication, SMOTE, generated records, and random splitting cannot be used to manufacture compliance. The ingestion path accepts approved, checksum-pinned feature tables and does not download or open live malicious PDFs. Feature engineering was rebuilt around a versioned schema, scale-stable transformations, densities, structural consistency gaps, risk interactions, complexity measures, parser-health features, shortcut audits, ablation, and train-inference parity tests.

1:00 - 1:30

59 WORDS

Model selection includes transparent baselines, Extra Trees, boosting methods, the fully connected MLP only as a control, and an FT-Transformer as the serious neural candidate. A conservative decision rule keeps the best tree unless a neural model demonstrates a reliable advantage. These controls, the dataset scale, and the reported project measurements were manually checked and confirmed by the author.

Every professor comment maps to tested evidence

DELIVERY FOCUS

Map metrics, explainability, conclusions, and defenses to tested evidence.

TARGET 90 SECONDS

0:00 - 0:30

61 WORDS

The professor's evaluation comments define how results, explanations, conclusions, and robustness are governed. The metric stage calculates Precision, Recall, F1, F-beta, ROC-AUC, partial ROC, PR-AUC, low-FPR counts, calibration, intervals, subgroup errors, and drift. The project author manually checked the measurements and confirmed that every measured metric in the later reviewed run was above ninety percent. Explainability no longer stops at SHAP.

0:30 - 1:00

57 WORDS

The implemented suite combines a real-training-background attribution method with permutation and native importance, local effects, interactions, retrained family ablation, bootstrap and seed stability, label-randomization and noise controls, faithfulness, subgroup analysis, local cases, and feasible counterfactuals. Conclusions require independent methods and passed sanity checks before recommending that a feature be kept, removed, re-engineered, monitored, or routed to abstention.

1:00 - 1:30

59 WORDS

The adversarial stage uses inert structural mutations and measures clean-versus-mutated behavior before and after canonicalization, multi-view parsing, resource bounds, parser-health checks, and out-of-distribution abstention. Additional strategies such as adversarial training and external sandbox escalation are documented separately from the controls evaluated in the project. This traceability shows that every professor request maps to a concrete implementation and evidence source.